

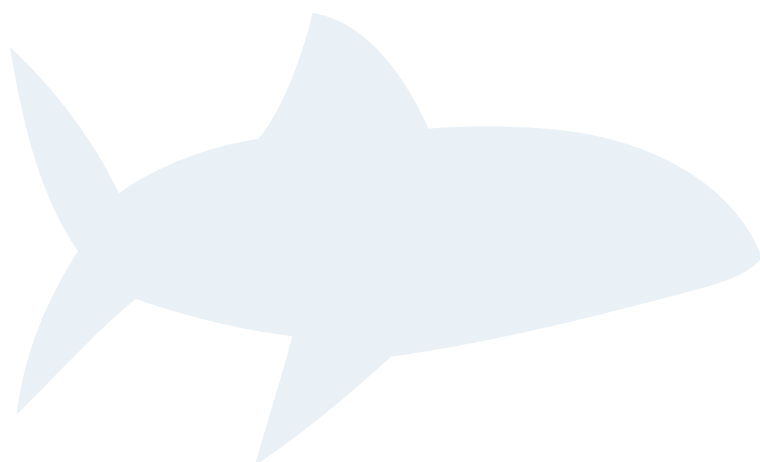


Security Overview

sharkshare platform — 15 public domains

Assessment date	2026-09-28 (revised 2026-09-29)
Type	Non-intrusive external probes + GitOps repository review
Authorization	Owner-authorized assessment of owned domains and repository
Sources	Live HTTP, TLS and DNS probes; sharkshare-gitops manifests, docs and CI
Companion	2026-09-28-yornik_eu.pdf — endpoint detail
Classification	Confidential — internal

This overview combines read-only external observation with a review of the GitOps repository. No intrusive testing was performed. One finding (O-08) was identified and corrected during the assessment; it is recorded in Section 6.



1. Executive summary

The sharkshare platform is a self-hosted estate on a 4-node Talos Kubernetes cluster. ArgoCD reconciles about 40 applications from the sharkshare-gitops repository, serving 15 public HTTPS domains.

The security engineering is strong, and in several respects ahead of common commercial practice. Traffic enters through 2 hardened edge hosts and a Tailscale mesh, so the cluster is never directly exposed. Secrets are encrypted with SOPS and age. Every change passes 7 CI checks, including a pinned-hash guard that blocks a dependency bump carrying a stale checksum, and signature verification of the published security.txt.

Every administrative and application login is authentication-gated, and the edge applies rate limiting plus a fail2ban filter. The assessment found **one exception** to that protection, on qbittorrent, where middleware ordering meant a failed login bypassed both controls. It was corrected and verified during the assessment (O-08).

No high severity issue was found. The dominant open theme is **exposure**, narrowly drawn: four administrative interfaces with no external-access requirement are reachable from any address, ArgoCD being the consequential one. Services that must be reachable to function — the vault above all — are deliberately public and hardened accordingly. The second theme is header coverage: Content-Security-Policy is set per application rather than estate-wide.

Open findings by severity

0 High	1 Medium	4 Low	2 Info
------------------	--------------------	-----------------	------------------

One further medium finding (O-08) was **resolved during the assessment** and is excluded from the counts above. Severity reflects external impact, not a CVSS score.

2. Architecture in brief

Drawn from the sharkshare-gitops technical overview and manifests.

Layer	Detail
Edge	2 Hetzner hosts (Nuremberg, Helsinki). HAProxy L4 with PROXY v2. Tailscale. fail2ban.
Transport	Tailscale mesh from the edge to the cluster. TLS terminates at Traefik (Let's Encrypt).
Compute	4 Intel N150 nodes, Talos Linux, 128 GiB total; 3 control-plane + 1 worker.
Data	3 CloudNativePG clusters (shared, OpenProject, GitLab), 3-instance HA, WAL archive to object storage.
Storage	TrueNAS SCALE over NFS, iSCSI and SMB. Postgres on iSCSI with sync=standard.
Observability	kube-prometheus-stack and Grafana; Alloy to Loki, 60-day retention.
Delivery	ArgoCD app-of-apps; GitHub webhook triggers sync; prune and selfHeal enforce git state.
Secrets	SOPS with age; KSOPS decrypts in the repo-server. No plaintext secret in git.



3. Public attack surface

Every public domain in the repository, with the external result observed on 2026-09-29. “Exposure” describes who can reach the login, not whether it is protected.

Domain	Service	Probe	Auth	Exposure
yornik.eu	Professional site	200, CSP+HSTS	Static	Public by design
fedishark.eu	Landing site	200, HSTS	Static	Public by design
pub.fedishark.eu	GoToSocial	200, CSP+HSTS	App login	Public (private instance)
secrets.yornik.eu	PrivateBin	200, CSP+HSTS	None (paste)	Public by design
omni.fedishark.eu	OmniTools	200, HSTS	None (client-side)	Public by design
grafana.fedishark.eu	Grafana	302 to login	App login	Internet-wide
argocd.fedishark.eu	ArgoCD + webhook	200, CSP+HSTS	App login + fail2ban	Internet-wide (admin)
asf.fedishark.eu	ArchiSteamFarm	200, HSTS	IPCPassword + fail2ban	Internet-wide (admin)
qbittorrent.fedishark.eu	qBittorrent	401, HSTS	basicAuth + fail2ban	Internet-wide (O-01, O-08)
jelly.yornik.eu	Jellyfin	302, HSTS	App login	Internet-wide
passwords.yornik.eu	Vaultwarden	200, CSP+HSTS	2FA + fail2ban	Public by necessity
todo.yornik.eu	Vikunja	200, HSTS	App login	Internet-wide
plan.yornik.eu	OpenProject	302 to /login	App login	Internet-wide
git.yornik.eu	GitLab CE	302 to sign_in	App login	Internet-wide
registry.git.yornik.eu	GitLab registry	200 (API root)	Token	Internet-wide
bokings-driessen.party	soiree planner	200, HSTS, noindex	App login	Internet-wide



4. Estate-wide controls that work well

Control	Evidence
Shared security headers	Traefik middleware sets HSTS (preload), nosniff, frameDeny and referrer no-referrer.
Rate limiting	Traefik rate-limit middleware: 300 average, 600 burst.
fail2ban at the edge	Attached to 12 IngressRoutes, plus dedicated filters for ArgoCD and ASF, and fail2ban on both jump hosts.
No direct cluster exposure	HAProxy L4 to a Tailscale mesh. The Kubernetes API is not internet-facing.
Encrypted secrets	SOPS and age; KSOPS decrypts in-cluster. No plaintext secret in git.
Supply-chain guard	A pinned-hash check blocks a KSOPS bump whose checksum does not match upstream.
PR-gated changes	7 CI checks: yamllint, signed security.txt, KSOPS hash, helm template, values render, kubeconform on raw and rendered output.
Signed disclosure	The published security.txt is PGP-signed and CI verifies the signature.
Modern TLS estate-wide	TLS 1.3 with Let's Encrypt on all 16 hosts; CAA restricts issuance to 5 authorities.
Backups	Continuous WAL archive and scheduled base backups to object storage for all 3 Postgres clusters.
Incident discipline	docs/incidents/ records each significant finding with cause, correction and prevention.
Hardened public vault	Vaultwarden runs with 2FA, registration disabled, a SOPS-supplied admin token and its own tuned fail2ban rule. See Section 5.



5. Open observations

O-01 MEDIUM Administrative interfaces reachable from the whole internet

Observation. Four interfaces with no external-access requirement accept connections from any address: **ArgoCD**, **Grafana**, **ArchiSteamFarm** and **qBittorrent**. ArgoCD is the significant one: it is the deploy control plane, so a compromise there is a compromise of everything it reconciles. Each enforces a login and sits behind fail2ban, but O-08 showed that this protection has to be verified per host rather than assumed.

Recommendation. Move these interfaces behind the Tailscale mesh or an IP allowlist. NOTE: ArgoCD cannot be moved wholesale — `/api/webhook` must stay reachable for the GitHub push trigger. Restrict the UI and leave that one path public, or narrow it to GitHub's published ranges from `api.github.com/meta`. Services that must be reachable from anywhere to do their job are out of scope for this finding; see the note below.

O-02 LOW Content-Security-Policy is per application, not estate-wide

Observation. The shared security-headers middleware sets no Content-Security-Policy. Five applications set their own (yornik.eu, PrivateBin, GoToSocial, ArgoCD, Vaultwarden). The rest send none, including Grafana, Jellyfin, Vikunja, OmniTools, ArchiSteamFarm and the landing site. Without a policy, a cross-site scripting flaw has fewer limits.

Recommendation. Add a conservative default policy to the shared middleware and relax it per application. Deploy in report-only mode first to find breakage before enforcing.

O-03 INFO Deprecated X-XSS-Protection header set estate-wide

Observation. The shared middleware sets `browserXssFilter`, so every application returns `x-xss-protection`. Modern browsers ignore it and older ones can introduce a side channel.

Recommendation. Remove `browserXssFilter`. The policy from O-02 is the correct control.

O-04 LOW security.txt discloses the full subdomain inventory

Observation. The signed file lists Canonical URLs for many hosts, including passwords., secrets., argocd. and grafana. An attacker gets a map of the estate without scanning for it.

Recommendation. Keep only the entries a researcher needs; move the full host list out of the public file.

O-05 LOW Email authentication is incomplete

Observation. DMARC is `p=quarantine` with no aggregate report address. No DKIM record was found at the common selectors, though SES uses its own rotating selectors. SPF ends in a soft fail.

Recommendation. Add an `rua` address, confirm SES DKIM alignment, then move to `p=reject` and `-all`.

O-06 INFO Software and version disclosure in Server headers

Observation. Server headers name the software and sometimes the version: `nginx/1.31.1`, `nginx/1.29.1`, `gotosocial`, `Kestrel`, `Rocket`.

Recommendation. Hide the version where the proxy allows it. A small gain; patching remains the main control.



O-07

LOW

Single points of failure for availability

Observation. The repository records one power feed, one internet uplink and one shared NAS for stateful workloads, documented as accepted homelab tradeoffs. This is an availability risk, not a breach risk.

Recommendation. Accept for a homelab, or add an independent uplink with its own battery. Keep the off-site backups current so a storage loss stays recoverable.

Exposure that is deliberate, and correct

Not every internet-facing service is a finding. A password manager that cannot be reached from an unfamiliar network cannot do its job, so **Vaultwarden is public by necessity**. The configuration reflects that, and it is the most thoroughly hardened service in the estate:

Control	Evidence
Two-factor authentication	Enabled on the vault.
Registration closed	SIGNUPS_ALLOWED="false" in the Deployment, so the public endpoint cannot be used to create an account.
Admin panel protected	ADMIN_TOKEN supplied from a SOPS secret, not a default.
Tuned brute-force filter	A dedicated fail2ban middleware (30 failures / 10 min / 1 h ban) rather than the shared rule.
Tuning is evidence-based	The manifest comment records that a stricter 3-in-4h rule locked a NAT'd household out of its own vault, and why the rule was widened.
Correct middleware order	Headers and fail2ban precede the application, so a rejected login is still counted (contrast O-08).

The same reasoning applies in weaker form to Jellyfin, GitLab, OpenProject, Vikunja and soiree: each has a plausible reason to be reachable. They are not counted in O-01. The four interfaces named there have no such rationale.



6. Resolved during the assessment

O-08

RESOLVED

A failed qBittorrent login bypassed fail2ban and rate-limit

Observation. Traefik runs a middleware list in order, and basicAuth ends the chain when it rejects a request. On qbittorrent.fedishark.eu the auth middleware was listed first, so a failed login never reached fail2ban, rate-limit or the security headers. That public login had no brute-force protection. A correct password traversed the whole chain, so the host looked healthy in normal use; only a rejected request revealed it.

```
before: qbittorrent-auth -> rate-limit -> fail2ban -> security-headers
after: security-headers -> fail2ban -> rate-limit -> ... -> qbittorrent-auth

verified 2026-09-29 after the ArgoCD sync, on the unauthenticated 401:
strict-transport-security: max-age=31536000; includeSubDomains; preload
```

Recommendation. Corrected. qbittorrent-auth moved to the end of the chain and security-headers to the front, matching the order vikunja, asf and argocd-config already use. Merged as PR #499 and recorded in docs/incidents/2026-09-29-qbittorrent-middleware-order.md. Apply the same rule to any middleware that can end a chain, including forwardAuth and ipAllowList.

How it was found

A header comparison across all 16 public hosts showed 15 returning strict-transport-security and one that did not. The missing header was the visible symptom; the absent brute-force protection was the substance. This is the practical argument for comparing hosts against each other rather than checking each in isolation.

7. Prioritized recommendations

1. Move the ArgoCD UI, Grafana, ArchiSteamFarm and qBittorrent behind Tailscale or an IP allowlist, keeping /api/webhook reachable for the GitHub trigger. (O-01)
2. Confirm multi-factor authentication on GitLab and Grafana, as it already is on the vault. (O-01)
3. Audit every IngressRoute for a chain-ending middleware placed before a protective one. (O-08)
4. Add a default Content-Security-Policy to the shared middleware, report-only first. (O-02)
5. Complete the email posture: DMARC reporting, SES DKIM, then p=reject. (O-05)
6. Trim the subdomain list in security.txt. (O-04)
7. Remove browserXssFilter and hide server versions. (O-03, O-06)
8. Run the active phases in a planned window; record the result in a follow-up.

8. Method and scope

The assessment combined two sources. First, live external probes of each public domain: HTTP status and headers, TLS handshake, and DNS records over DNS-over-HTTPS. Second, a read-only review of the sharkshare-gitops repository: the technical overview, the Traefik middleware, every IngressRoute and the CI configuration.

The probes were read-only. The assessment did not authenticate to any service, scan ports, test input fields or read any encrypted secret. Reading the manifests alongside the probe results is what surfaced O-08, which neither source would have shown alone.



Revision history

Date	Change
2026-09-28	Initial assessment: 16 public domains, repository review.
2026-09-29	Re-probed all hosts (no drift). Added O-08 and its correction. Corrected the O-01 claim about brute-force protection. Narrowed O-01 to the four interfaces with no external-access requirement, after confirming the vault is public by necessity and already hardened. Fixed the informational count in the severity summary.

9. Appendix — probe evidence

Collected 2026-09-29 with curl and DNS-over-HTTPS. One line per host.

```
yornik.eu 200 nginx/1.31.1 CSP HSTS
fedishark.eu 200 nginx/1.31.1 HSTS landing page
pub.fedishark.eu 200 gotosocial CSP HSTS private instance
grafana.fedishark.eu 302 -> login HSTS
argocd.fedishark.eu 200 Argo CD CSP HSTS fail2ban
asf.fedishark.eu 200 ASF HSTS IPCPassword + fail2ban
qbittorrent.fedishark.eu 401 basicAuth HSTS headers restored (O-08)
omni.fedishark.eu 200 nginx/1.29.1 HSTS
jelly.yornik.eu 302 Kestrel HSTS Jellyfin
passwords.yornik.eu 200 Rocket CSP HSTS Vaultwarden
todo.yornik.eu 200 Vikunja HSTS
secrets.yornik.eu 200 nginx CSP HSTS PrivateBin
plan.yornik.eu 302 -> /login HSTS OpenProject
git.yornik.eu 302 -> sign_in HSTS GitLab CE
registry.git.yornik.eu 200 registry API HSTS
bokings-driessen.party 200 soiree CSP HSTS X-Robots-Tag: noindex
```

End of overview. This reflects the external state and the repository content on 2026-09-29.